

Medicare Connect (Pty) Ltd
POPIA Section 21 Operator Agreement(Data Processing Agreement)
Aligned to ISO 27001:2022 controls A.5.19 - A.5.22 and POPIA Section 21

Entered into between :
Medicare Connect (PTY) Ltd
Registration No : 2018/234567/07
Responsible Party

And

Vendor Name (PTY) Ltd
Registration No :
Operator

1. PREAMBLE

- 1.1 Under the Protection of Personal Information Act 4 of 2013 (POPIA), MediCare Connect acts as the Responsible Party for personal information processed in connection with healthcare services.
- 1.2 The Operator provides Pathology API Services which requires processing personal information on behalf of the Responsible Party.
- 1.3 POPIA Section 21 mandates that processing by an Operator must be governed by a written contract establishing security safeguards.

2. OPERATOR OBLIGATIONS (POPIA SECTION 20 & 21)

- 2.1 Authorization:** The Operator shall process personal information ONLY with the knowledge or authorization of MediCare Connect and strictly according to documented instructions.
- 2.2 Confidentiality:** The Operator shall treat all personal information, clinical data, and patient identity records as strictly confidential and ensure employees sign non-disclosure agreements.
- 2.3 Technical & Organizational Safeguards:** The Operator warrants that it implements security measures equivalent to ISO/IEC 27001:2022 Annex A controls, including:
- a) Full-disk encryption (AES-256) for data at rest and TLS 1.3 for data in transit.
 - b) Multi-Factor Authentication (MFA) for all remote and admin access.
 - c) Role-Based Access Controls (RBAC) enforcing least privilege.
 - d) Daily off-site encrypted backups.

3. MANDATORY SECURITY BREACH NOTIFICATION (POPIA SECTION 22)

- 3.1 In the event of an actual or suspected security compromise, data breach, or unauthorized access to MediCare Connect data, the Operator SHALL:
- a) Notify MediCare Connect's Information Officer via email and phone WITHIN 24 HOURS of discovery.
 - b) Provide details of personal information affected, data subjects impacted, and immediate containment measures taken.
 - c) Refrain from making public announcements or notifying the Information Regulator without prior written approval from MediCare Connect.

4. AUDIT & INSPECTION RIGHTS

- 4.1 MediCare Connect reserves the right, upon 14 days' written notice, to conduct an independent audit or request certified third-party audit reports (e.g., ISO 27001 certificate, SOC 2 Type II report) verifying the Operator's compliance with this Agreement.

5. DATA RETENTION & DESTRUCTION (POPIA SECTION 14)

5.1 Upon termination of services, the Operator shall, within 30 days, securely return or destroy all personal information, backups, and derivative data using DoD 5220.22-M or NIST 800-88 sanitization standards, and provide a written Certificate of Destruction.

6. GOVERNING LAW & JURISDICTION

6.1 This Agreement is governed by the laws of the Republic of South Africa. Any dispute relating to POPIA non-compliance shall be submitted to the Information Regulator of South Africa.

DATED AT SANDTON ON THIS ____ DAY OF _____ 2026.

For: MediCare Connect (Pty) Ltd
Name: CEO Name
Capacity: Chief Executive Officer

For: [Vendor Name (Pty) Ltd]
Name: Vendor Director
Capacity: Managing Director
